

Developing a Zero Trust focused Cybersecurity Policies and Compliance Plan for a Small Cloud-Based Accounting Firm : FintSecure Accounting Services

Team/Students: Ademola Daniel Aderibigbe & Tarun Margam | Business Advisor: Michael Carter | Dr. Yair Levy, Professor of Information Systems and Cybersecurity

Introduction

The adoption of cloud computing within the financial services sector has transformed how organizations manage and process sensitive financial data, particularly among small accounting firms that rely on cloud-based infrastructures for operational efficiency and scalability (NIST, 2024; IBM, 2025). As organizations increasingly migrate to cloud environments, they face heightened exposure to cybersecurity threats such as identity compromise, unauthorized access, insider threats, and cloud misconfigurations, which are exacerbated by the multi-tenant and dynamic nature of cloud systems (Ziani & Medouri, 2018). Industry research indicated that data breaches continue to result in substantial financial and reputational impacts globally, highlighting the growing importance of effective cybersecurity governance (IBM, 2025). Zero Trust Architecture (ZTA) has emerged as a modern cybersecurity paradigm that eliminates implicit trust and requires continuous verification of users, devices, and access requests regardless of network location (NIST, 2020). Its core principles, including least privilege access, strong Identity and Access Management (IAM), and continuous monitoring, are critical for mitigating risks associated with cloud-based environments. Furthermore, the National Institute of Standards and Technology Cybersecurity Framework (NIST CSF 2.0) (2024) provides structured guidance for organizations to manage cybersecurity risks through governance, cyber risk management, and continuous improvement processes. Research indicated that weaknesses in identity management, human behavior, and organizational cybersecurity practices contribute significantly to cybersecurity incidents, reinforcing the need for integrated, policy-driven, and compliance plan-focused approaches (NIST, 2020; 2024).This proposed project focuses on the development of Zero Trust focused Information Security Policies and a compliance plan by designing a Zero Trust cybersecurity policies tailored for a small cloud-based accounting firm. This project aims to develop structured policies aligned with Zero Trust principles and supported by a continuous compliance plan that enhances governance, monitoring, and enforcement.

Problem Definition

Research indicated that cloud misconfigurations, weaknesses in IAM, and insufficient monitoring capabilities are among the leading contributors to security incidents in cloud environments (NIST, 2020; 2024). These challenges are further intensified by increasingly sophisticated cyber threats targeting sensitive financial and organizational data (NIST, 2024).A primary cybersecurity concern in modern environments is identity compromise, which occurs through threats such as phishing attacks, credential theft, and weak authentication mechanisms (NIST, 2020). Industry findings indicated that compromised credentials remain a dominant attack vector, enabling unauthorized access to critical systems and sensitive data (IBM, 2025). Traditional perimeter-based cybersecurity models, which assume trust within internal networks, are no longer effective in cloud environments where users, devices, and services operate across multiple network boundaries. This shift increases the likelihood of unauthorized access and lateral movement within systems (NIST, 2020). Insider-related threats represent a significant cybersecurity concern, arising from both malicious actions and unintentional user behavior involving authorized access. Weak access control practices and inadequate cybersecurity policies can increase the risk of misuse of privileges and unauthorized data access, particularly in cloud environments (Veloudis et al., 2017; Ziani & Medouri, 2018). These risks highlight the importance of governance-driven controls and continuous monitoring to effectively manage user access and protect sensitive data (Hegde et al., 2023).Organizations also encounter challenges in implementing effective and maintaining consistent compliance in cloud-based environments. Research also indicated that the effectiveness of cloud security largely depends on well-defined and enforceable cybersecurity policies, as inadequate cybersecurity policies can undermine trust and hinder the improvement of secure cloud adoption (Veloudis et al., 2017). ZTA addresses these challenges by attempting to eliminate implicit trust and requiring continuous authentication and authorization for all access requests (NIST, 2020). ZTA reduces the likelihood of unauthorized access and limits the potential impact of security incidents by enforcing strict identity verification and access control mechanisms. However, many organizations have not yet implemented comprehensive information security policies and compliance plans to support effective adoption of Zero Trust principles within cloud environments. Overall, the increasing reliance on cloud technologies, combined with weaknesses in identity governance, insider risk management, and compliance enforcement, creates significant cybersecurity risks across organizations. Addressing these challenges requires a structured approach that integrates Zero Trust principles with formalized and continuous compliance mechanisms aligned with the NIST CSF.

Facts

The organization under investigation , a small cloud-based accounting, FintSecure Accounting Services, manages highly sensitive data, including Personally Identifiable Information (PII), financial records, and tax-related documents. The nature of this data increases the organization's exposure to cybersecurity and regulatory risks, particularly in cloud-based environments where identity and access controls play a critical role in protecting information assets (NIST, 2024). Although the organization has implemented several cybersecurity technologies, it does not maintain a formalized information security policy and compliance plan, resulting in weaknesses in governance and inconsistent compliance practices. This condition reflects a misalignment between deployed technical controls and policy-driven enforcement mechanisms. From an organizational perspective, the firm does not maintain a formalized information security leadership role, and cybersecurity responsibilities are assigned to a small information technology (IT) team focused primarily on operational support. As a result, critical information security policies, including access control, data classification, and incident response, are not consistently formalized or enforced. The NIST CSF 2.0(2024) emphasizes the importance of governance structures and clearly defined cybersecurity policies to support effective risk management and accountability .Culturally, the organization demonstrates limited cybersecurity awareness and minimal enforcement of acceptable cybersecurity practices. Employees often prioritize operational efficiency over adherence to, which contributes to behaviors such as credential sharing and bypassing multi-factor authentication (MFA). Research indicated that human behavior and organizational culture are significant contributors to cybersecurity incidents, particularly in environments without strong cybersecurity policy enforcement and accountability mechanisms (NIST, 2024). From a technological standpoint, the organization utilizes cloud-based tools such as Microsoft Entra ID, Microsoft 365, Microsoft Defender for Endpoint, and Microsoft Sentinel. While these technologies provide capabilities that support identity management and monitoring, their effectiveness depends on governance through formal. Current conditions include limited enforcement of MFA across all users, excessive assignment of privileged access, absence of conditional access policies, and insufficient review of logging and monitoring data. The NIST CSF highlights continuous monitoring and access control governance as essential components of an effective cybersecurity program (NIST, 2024). Behavioral factors further contribute to organizational risk exposure. Users demonstrate weak password practices, reuse credentials across systems, and exhibit susceptibility to phishing-related threats. Additionally, access to sensitive organizational data from unmanaged or personal devices increases the likelihood of data exposure. These behaviors are influenced by insufficient enforcement of acceptable use and cybersecurity awareness policies, as well as limited accountability structures within the organization. Overall, the organization does not currently operate under a structured Zero Trust-aligned information security policy and compliance plan, resulting in gaps across organizational, cultural, technological, and behavioral dimensions. These conditions reduce the organization's ability to manage cybersecurity risks effectively and highlight the need for a governance-driven approach that integrates Zero Trust principles with formalized cybersecurity policies development and a continuous compliance plan aligned with the NIST CSF.

Project Scope and Goals

This proposed project focuses on the development of a Zero Trust cybersecurity policies and compliance plan for a small cloud-based accounting firm. The scope of this proposed project is limited to addressing critical cybersecurity challenges related to IAM, insider-related risks, cloud governance, and compliance enforcement. The focus remains on information security policy development and compliance plan, rather than technical implementation or procedural configurations. The scope includes the development of formalized information security policies, and a compliance plan aligned Zero Trust principles, including identity and authentication, access control, data protection, acceptable use, logging and monitoring, and incident response. In addition, this proposed project includes the design of a continuous compliance plan that supports policy enforcement, monitoring, and accountability across the organization. These policies will be aligned with the NIST (CSF) 2.0, which provides structured guidance for governance, risk management, and continuous improvement of cybersecurity practices (NIST, 2024). The primary goal of this proposed project is to strengthen the organization's information security policy development and continuous compliance capabilities by establishing a structured and enforceable governance policies. Specifically, the project aims to improve identity and access governance through cybersecurity policies aligned with Zero Trust principles such as least privilege and continuous verification (NIST, 2020). This project will also aim to reduce risks associated with unauthorized access and insider-related activities through clearly defined and enforceability. Attempt to strengthen compliance posture by introducing a continuous compliance plan that supports monitoring, accountability, and policy enforcement (NIST, 2024). Enhance organizational cybersecurity governance by aligning policies with the NIST (CSF) 2.0 and supporting risk-informed decision-making processes. The intended outcome of this proposed project is to provide the organization with structured, standard-aligned cybersecurity policies and compliance plans that improve its ability to manage cybersecurity risks, protect sensitive financial data, and support long-term governance and regulatory readiness.

Risk Management and Analysis

The identified risks highlight critical gaps in identity governance, access control, cloud management, and compliance enforcement (NIST, 2024). The most critical risks—identity compromise and excessive privileges—highlight the need for Zero Trust principles such as continuous verification and least privilege. Additional risks, including cloud misconfigurations, weak monitoring, and poor policy enforcement, emphasize the importance of structured cybersecurity policies supported by a continuous compliance plan. The proposed action items align with the NIST CSF (NIST, 2024) and form the basis for the recommended solution.

Table 1: Risk Management Summary

Risk Rank	Cyber Threat	Cyber Risk	Likelihood	Impact	Action Item
1	Phishing / Credential Theft	Unauthorized access to sensitive financial and PII data due to successful phishing attacks and compromised credentials	High	High	ACT1 – Develop identity and authentication policy enforcing MFA and least privilege access
2	Excessive Privileges / Insider Threat	Data exposure or unauthorized modification of financial records due to misuse of privileged access by internal users.	High	High	ACT2 – Develop and enforce access control policy based on least privilege and role-based access governance
3	Cloud Misconfiguration	Exposure of sensitive financial data due to exploitation of misconfigured cloud storage or services.	High	High	ACT3 – Establish cloud security governance and configuration management policy aligned with Zero Trust principles
4	Credential Compromise/Weak Authentication Practices	Unauthorized system access and lateral movement due to compromised credentials and weak authentication mechanisms.	High	High	ACT1 – Strengthen identity and authentication policy with enforced MFA and password standards
5	Logging and Monitoring Invasion	Increased impact of cybersecurity incidents due to delayed detection resulting from ineffective logging and monitoring processes.	Medium	High	ACT4 – Implement logging, monitoring, and auditing policy with continuous compliance checks
6	Data Mismanagement	Leakage or unauthorized disclosure of sensitive financial data due to improper data handling and classification practices.	Medium	High	ACT6 – Establish data classification and data protection policy aligned with compliance requirements
7	Insider Negligence / Human Error	Accidental data exposure or system compromise due to user errors such as mishandling sensitive information or failing victim to phishing.	High	Medium	ACT5 – Develop security awareness and acceptable use policy with enforcement mechanisms
8	Exploitation of Ineffective Incident Response Processes	Extended operational disruption and increased recovery time due to ineffective incident response processes during cybersecurity incidents.	Medium	Medium	ACT7 – Develop incident response and recovery policy aligned with NIST guidelines

Recommended Solution and Action Plan

The recommended solution and action plan is a set of Zero Trust cybersecurity policies advancing the organization from NIST CSF Tier 1 (Partial) to Tier 2 (Risk-Informed), structured by the NIST CSF 2.0 (2024) functions Identify, Protect, and Detect, and validated with the McCumber Cube to maintain balanced attention to human factors, policy, and technology (McCumber, 2004; National Institute of Standards and Technology, 2020; 2024). All controls are mapped to identified risks, enabling continuous compliance, stronger governance, and improved cybersecurity posture in cloud-based financial environments.

Table 3 : Recommended Solution

Solution ID	NIST Function	NIST CSF 2.0(2024)Category	Subcategory	McCumber Cube	Plan Type	Action Plan
M1	Protect (PR. AA)	Access Control	PR.AA-1	Data / Technology	Managerial	Establish identity and authentication policies enforcing MFA
M2	Protect (PR. AA)	Access Control	PR.AA-4	Technology / People	Managerial	Define and enforce least privilege and RBAC policies
M3	Identify (GV.PO)	Governance	ID.GV-1	Technology	Managerial	Develop cloud security governance policies
M4	Detect (DE. CM)	Security Continuous Monitoring	DE.CM-1	Technology / Data	Technical	Establish centralized logging and monitoring policies
M5	Protect (PR. AT)	Data Security	PR.DS-1	People	Managerial	Develop data classification and protection policies
M6	Protect (PR. DS)	Awareness & Training	PR.AT-1	Data	Managerial	Establish security awareness and training program
M7	Respond (RS.RP)	Response Planning	RS.PS-1	Technology / People	Managerial	Develop incident response policies

Table 4 : Action Plan

ACT #	Solution ID	Action Plan Description	NIST Function		McCumber Cube	Plan Type	Risk Addressed
ACT1	M1	Develop and enforce identity and authentication policies requiring MFA and continuous verification	Protect		Data / Technology	Managerial	Unauthorized access to sensitive financial and PII data due to successful phishing attacks and compromised credentials
ACT2	M2	Define and enforce access control policies based on least privilege and RBAC	Protect		Technology / People	Managerial	Data exposure due to misuse of privileged access (insider threat)
ACT3	M3	Develop cloud governance policies addressing configuration management and access controls	Identify	Protect	Technology	Managerial	Exposure of sensitive data due to cloud misconfiguration
ACT4	M4	Establish logging and monitoring policies to support anomaly detection and visibility	Detect		Technology / Data	Managerial	Increased impact of incidents due to delayed detection from ineffective monitoring
ACT6	M5	Develop data classification and protection policies for sensitive financial data	Protect		People	Managerial	Data leakage due to improper data handling and mismanagement
ACT5	M6	Implement security awareness and training policies to reduce human-related risks	Protect		Data	Managerial	Accidental data exposure due to insider negligence and human error
ACT7	M7	Develop incident response policies to support timely response and recovery	Respond	Recover	Technology / People	Managerial	Extended operational disruption due to ineffective incident response processes

Anticipated Results

This proposed Zero Trust cybersecurity policies and compliance plan is expected to improve the organization's cybersecurity posture by strengthening governance, reducing risk exposure, and improving compliance. The implementation of structured, standard-aligned cybersecurity policies and compliance plan will enable a consistent and risk-informed approach to cybersecurity management (NIST, 2024). Operationally, this proposed project is expected to improve monitoring and incident response through formal logging and response policies, enabling earlier detection of security events and better coordination. Clearly defined roles and governance structures are expected to improve accountability and decision-making. In terms of communication security, implementing identity and access management policies based on Zero Trust principles—such as MFA, least privilege, and continuous verification—is expected in reducing unauthorized access and limit lateral movement, protecting sensitive financial data. From a data and network security perspective, data classification and protection policies will attempt to strengthen and safeguard sensitive information, including PII and financial records. Improved cloud governance and monitoring will enhance visibility and reduce risks related to misconfigurations and data exposure. Overall, this proposed project will move the organization from NIST CSF Tier 1 (Partial) to Tier 2 (Risk-Informed), establishing defined policies, stronger governance, and integrated risk management. This will attempt to enable proactive risk management, improved resilience, improved security and compliant operations in a cloud-based environment(NIST, 2024).

(NIST, 2024)

Proposed Cost

The proposed costs reflect a policy-driven implementation approach aligned with the NIST CSF (NIST, 2024), focusing on governance and compliance rather than infrastructure expansion.

Table 5: Proposed Cost

Equipment / Service Item	Performed By	ACT #	Cost per Item (\$)	# of Items	Total (\$)
Identity & MFA Policy Development	Internal IT Team	ACT1	\$1,200.00	1	\$1,200.00
Access Control Policy Development	Internal IT Team	ACT2	\$1,000.00	1	\$1,000.00
Cloud Security Governance Policy Development	Contractor (Security Consultant)	ACT3	\$2,500.00	1	\$2,500.00
Logging & Monitoring review policy development	Internal IT Team	ACT4	\$1,500.00	1	\$1,500.00
Data Classification & Protection Policy Implementation	Internal IT Team	ACT6	\$1,200.00	1	\$1,200.00
Security Awareness Training Program	Contractor (Training Provider)	ACT5	\$ 800.00	1	\$ 800.00
Incident Response Plan Development	Contractor (Security Consultant)	ACT7	\$1,800.00	1	\$1,800.00
				TOTAL	\$10,000.00

Conclusion

This project aims to develop Zero Trust cybersecurity policies and continuous compliance plan for a small cloud-based accounting firm, focusing on key risks such as identity and access management, insider threats, cloud governance, and compliance enforcement. The goal is to attempt to strengthen cybersecurity through structured, enforceable cybersecurity policies and continuous compliance rather than informal practices. This proposed project introduces a governance-driven approach aligned with the NIST CSF, improving the organization's ability to protect sensitive financial data, enhance accountability, and maintain regulatory compliance. The inclusion of a continuous compliance plan supports ongoing enforcement and monitoring of policies. Strategically, this proposed project advances the organization from NIST Tier 1 (Partial) to Tier 2 (Risk-Informed), enabling a shift from reactive to proactive, policy-driven cybersecurity governance (NIST, 2024). This proposed project demonstrates how structured information security policies and continuous compliance mechanisms can transform organizational cybersecurity maturity from reactive practices to risk-informed governance aligned with the NIST CSF.

References

Hegde, T., Gangli, J., Babenko, S., & Coffman, J. (2023). Cloud security frameworks: Comparison to evaluate cloud control standards. In *Proceedings of the IEEE/ACM International Conference on Utility and Cloud Computing*. <https://doi.org/10.1145/3603166.3632553>

IBM. (2025). *Cost of a data breach report 2025*. IBM Security. <https://www.ibm.com/reports/data-breach>

National Institute of Standards and Technology. (2020). *Zero trust architecture* (SP 800-207). U.S. Department of Commerce. <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf>

National Institute of Standards and Technology. (2024). *Cybersecurity framework (CSF) 2.0*. U.S. Department of Commerce. <https://www.nist.gov/cyberframework>

SANS Institute. (2026a). *Cloud service provider management policy template*. SANS Security Policy Resource.

SANS Institute. (2026b). *Identity management policy template*. SANS Security Policy Resource.

Veloudis, S., Paraskakis, I., & Petso, C. (2017). Ontological definition of governance framework for security policies in cloud environments. In *Proceedings of the Pan-Hellenic Conference on Informatics*. <https://doi.org/10.1145/3139367.3139401>

Ziani, A., & Medouri, A. (2018). Risks and security requirements for cloud environments. In *Proceedings of the International Conference on Smart City Applications*. <https://doi.org/10.1145/3286606.3286865>